Güvenlik Raporu: Canlı Kripto Piyasa Panosu

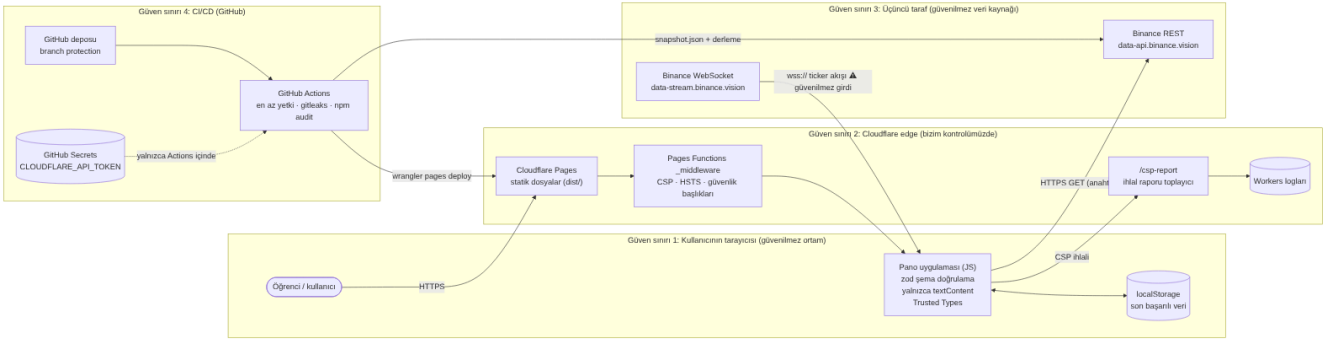
Arda Alaçamlı · 2516016006 · Bulut Bilişim ve Siber Güvenlik · Haftalık Sprint: Güvenli Bulut Yayını · Öğr. Gör. Osman Can Çetlenbik · 29 Ekim 2026
Ürün: https://kripto-piyasa-panosu.pages.dev · Depo: github.com/ArdaAlacamli35/kripto-piyasa-panosu

1. Yönetici özeti

> Gerçek zamanlı kripto fiyat panosu Cloudflare Pages'e taşındı. Altyapı `wrangler.toml` ve GitHub Actions ile kod olarak tanımlandı. Kartımdaki öncelikli tehdit, **WebSocket'ten gelen kötü niyetli verinin arayüzde script çalıştırması (XSS)** ve **CSP'nin wss için gevşetilmesi**. Bu tehdide karşı dört katmanlı bir savunma kuruldu: gelen her mesaja zod şema doğrulaması, DOM'a yalnızca `textContent` ile yazma, Trusted Types ve `unsafe-inline` içermeyen, `connect-src`'si yalnızca iki tam Binance adresine izin veren sıkı bir CSP.
>
> Yerel sahte WebSocket sunucusundan gönderilen **11 zararlı yükün 11'i de reddedildi** ve hiçbir script çalışmadı. İkinci katman testlerinde Trusted Types ve CSP 5 ihlali engelleyip rapor uç noktasına iletti (24/24 kontrol geçti). OWASP ZAP bulguları **3 orta / 4 düşük** riskten **0 orta / 1 düşük** riske indi; kalan tek düşük bulgu bilinçli olarak kabul edildi. Mozilla Observatory notu **C (55) → A+ (155)**. Hiçbir anahtar istemcide ya da depoda yok. Maliyet **0 TL**.

11/11	3 → 0	A+	0 TL
zararlı WebSocket yükü engellendi	ZAP orta risk (yüksek: hiç yok)	Observatory (12/12 test)	maliyet; ödeme yöntemi yok + bütçe alarmı

2. Mimari



Şekil 1. Veri akışı ve dört güven sınırı: (1) kullanıcının tarayıcısı, (2) Cloudflare edge, (3) üçüncü taraf veri kaynağı (Binance), (4) CI/CD (GitHub). WebSocket akışı, güven sınırı 3'ten 1'e geçen ve doğrulanmadan kullanılamayan güvenilmez girdidir.

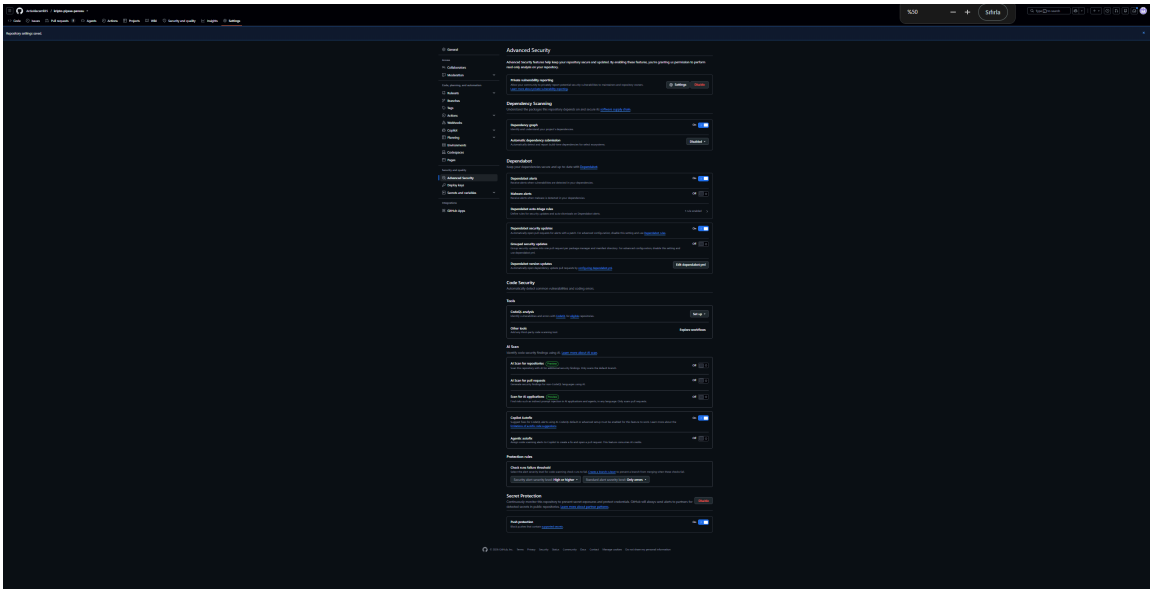
Bileşen	Tanım	Kod olarak mı?
Cloudflare Pages projesi	Statik dosyalar (`dist/`) + Pages Functions	`wrangler.toml`, yayın sırasında `pages project create`
Güvenlik başlıkları (edge)	Her yanıta CSP, HSTS vb. ekler, joker CORS'u siler	`functions/_middleware.js`
CSP rapor toplayıcı	İhlalleri boyut sınırıyla, kısaltarak loglar	`functions/csp-report.js`
CI/CD, izleme, tarama	CI, yayın, saatlik izleme, kullanım bekçisi, ZAP, Scorecard	`.github/workflows/*.yml` (6 iş akışı)
Portaldan kurulanlar	Cloudflare hesabı ve 2 API token'ı · GitHub Secrets (3) · GitHub Advanced Security ayarları · branch protection · Cloudflare bütçe alarmı. Token'lar doğası gereği koda yazılamaz.	

Kimlikler ve en az yetki

Kimlik	Yetki	Neden gerekli
`CLOUDFLARE_API_TOKEN`	Cloudflare Pages: Edit · tek hesap · 90 gün	Actions'ın siteyi yükleyebilmesi için gereken tek izin; DNS, fatura veya diğer ayarlara erişemez.
`CLOUDFLARE_ANALYTICS_TOKEN`	Account Analytics: Read · 90 gün	Kullanım bekçisinin yalnızca istek sayısını okuması için; hiçbir şeyi değiştiremez.
CI / yayın GITHUB_TOKEN	`contents: read`	Kodu okumak dışında depoya yazmaması için.
İzleme, kullanım bekçisi	`permissions: {}`	Yalnızca dışarıdaki siteyi/API'yi yoklar, GitHub API'sine hiç erişmez.
Scorecard	`security-events: write`, `id-token: write`	Sonucu Code Scanning'e ve OpenSSF'e imzalı yüklemek için; yalnızca bu işte.
Tarayıcı	Anahtar yok	Binance piyasa verisi anahtarsızdır; istemcide sır olmadığından vekil fonksiyon gerekmez.

3. Gizli anahtarlar ve CI/CD

- **Anahtar yalnızca kasada:** Cloudflare token'ları yalnızca GitHub Secrets'ta durur ve yalnızca Actions içinde kullanılır. `.env` ve `.dev.vars` `.gitignore`'dadır.
- **Secret scanning:** CI'da **gitleaks** tüm geçmişi tarar. GitHub **secret scanning + push protection** açıktır: sır içeren bir push sunucuda reddedilir.
- **Bağımlılık taraması:** `npm audit --audit-level=high` (yüksek seviyede CI durur), **Dependabot** uyarıları, güvenlik güncellemeleri ve haftalık sürüm güncellemeleri (npm + GitHub Actions). Kod taraması için **CodeQL** açıktır.
- **Tedarik zinciri:** Tüm GitHub Actions eklentileri değiştirilemez **commit SHA** ile sabitlenmiştir (ör. `actions/checkout@11d5960… # v4.4.0`). Ayrıca `npm ci` + `package-lock.json` kullanılır.
- **Branch protection:** `main` dalına doğrudan push kapalıdır. Değişiklik PR ile gelir ve CI kontrolünün geçmesi zorunludur.
- **Kendi kodumuz için kural:** CI'daki `check:dom` adımı `innerHTML`, `insertAdjacentHTML`, `eval`, `new Function` gibi ifadeler bulursa derlemeyi durdurur.



Şekil 2. GitHub Advanced Security: Dependabot uyarıları ve güncellemeleri, secret scanning, push protection, özel güvenlik bildirimi açık.

4. Tehdit modeli (STRIDE)

Veri akış diyagramı (Şekil 1) üzerinde 11 tehdit incelendi. Risk = olasılık × etki (1–5). Tam tablo: `docs/tehdit-modeli.md`. Kartımdaki tehditler (T1, T2) vurgulanmıştır.

#	STRIDE	Tehdit	Risk	Önlem	Kalan
T1	Tampering → EoP	WebSocket mesajıyla XSS (kartın tehdidi)	4×5=20	Zod şema, 4 KB sınırı, yalnızca textContent, Trusted Types, CSP	2
T2	Info. disclosure	CSP connect-src'nin wss için gevşetilmesi	3×4=12	connect-src = 2 tam adres; saatlik izleme CSP'yi denetler	2
T5	Info. disclosure	Cloudflare token'ının koda/loga sızması	3×5=15	GitHub Secrets, tek izin, 90 gün, gitleaks, push protection	4
T6	Tampering	Bağımlılık / eklenti tedarik zinciri	2×5=10	lockfile, npm audit, Dependabot, eklentiler SHA ile sabit	3
T8	DoS	Binance API'sinin çökmesi / hız sınırı	4×3=12	Yeniden bağlanma, son başarılı veri, günlük snapshot	3
T7	EoP	Workflow'lara fazla yetki	2×4=8	permissions en düşük, persist-credentials: false	2
T3	Spoofing	Ortadaki adam / sahte site	2×3=6	HTTPS + HSTS preload	2
T9	DoS	/csp-report uç noktasına istek yağmuru	2×2=4	8 KB sınır, kısaltılmış log, kullanım alarmı	2
T4	Tampering	Clickjacking	2×2=4	frame-ancestors 'none', X-Frame-Options	1
T10	Repudiation	Yayını kimin yaptığı bilinmez	2×2=4	Yalnızca Actions'tan yayın, PR zorunlu	1
T11	Info. disclosure	Rapor loglarına kişisel veri girmesi	2×2=4	Alan seçimi, 200 karakter sınırı, IP/çerez yok	1

Kartın tehdidi ayrıntılı: WebSocket kaynaklı XSS ve gevşek CSP

Senaryo. Binance akışı bizim kontrolümüzde değil. Akış ele geçirilebilir, bir ara katman veriyi değiştirebilir ya da bir hata beklenmedik veri üretebilir. Örneğin sembol alanında `<img src=x onerror=…>` gelebilir. Kod bu değeri `innerHTML` ile yazsaydı saldırganın kodu kullanıcının tarayıcısında çalışır, localStorage'ı okur, sahte fiyat gösterir ya da kullanıcıyı başka siteye yönlendirirdi. CSP'de `connect-src wss:` gibi bir joker olsaydı, çalışan kod veriyi istediği sunucuya gönderebilirdi.

Dört katman (biri aşılırsa diğeri durdurur): **(1) Zod şeması:** Mesaj önce 4 KB sınırından, sonra JSON çözümlemesinden, sonra şemadan geçer. Sembol yalnızca 5 değerden biri, fiyat yalnızca `^-?\d{1,20}(\.\d{1,12})?$` olabilir, akış adı sembolle eşleşmelidir. Fazla alanlar atılır. CSP'de `unsafe-eval` olmadığı için zod "jitless" modda çalışır. **(2) Yalnızca textContent:** Tek DOM yardımcısı metni düz metin yazar, öznitelikler izin listesinden geçer. **(3) Trusted Types:** `require-trusted-types-for 'script'`. Tek izinli politika `sw`'dir ve yalnızca `/sw.js` adresini kabul eder. **(4) CSP:**

```
default-src 'none'; script-src 'self'; style-src 'self'; img-src 'self' data:; font-src 'self'; connect-src 'self'
https://data-api.binance.vision wss://data-stream.binance.vision; manifest-src 'self'; worker-src 'self'; base-uri
'none'; form-action 'none'; frame-ancestors 'none'; upgrade-insecure-requests; require-trusted-types-for 'script';
trusted-types sw; report-uri /csp-report
```

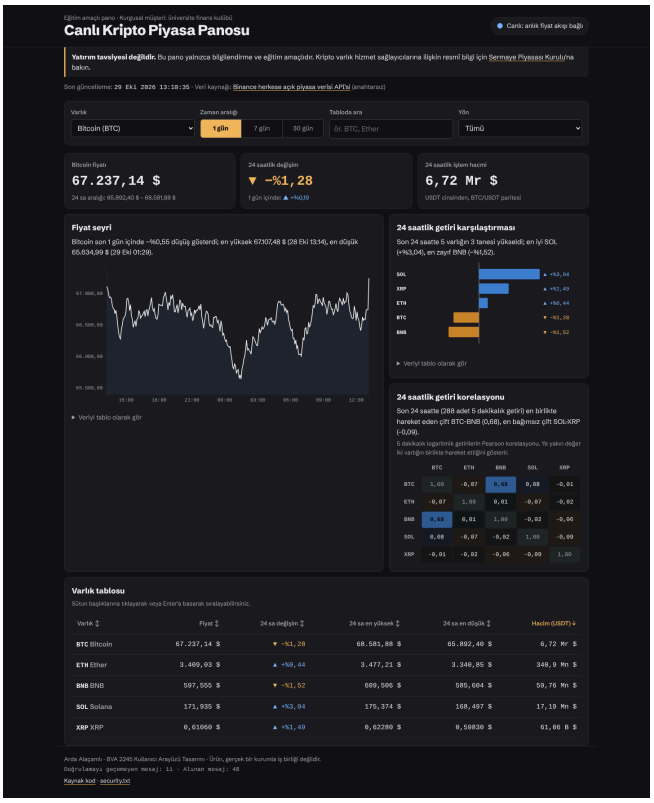
5. Güvenlik testleri

5.1 Kartın doğrulama testi: sahte WebSocket sunucusu

`npm run test:security` yerelde bir sahte Binance (REST + WebSocket, yalnızca 127.0.0.1) ve aynı edge kodunu çalıştıran Cloudflare Pages yerel sunucusu açar, ardından gerçek bir Chromium'la uygulamayı test eder. **Gerçek Binance'e hiçbir test isteği gönderilmedi.** Gönderilen zararlı yükler:

- XSS: sembol alanında <img onerror>
- XSS: fiyat alanında <script>
- XSS: akış adında
- Akış ile sembol uyuşmuyor (sahte ETH akışında BTC)
- Bilinmeyen sembol (DOGEUSDT)
- Sayı istismarı: 1e309 (sonsuz)
- Sayı istismarı: NaN
- Negatif fiyat
- Tür karmaşası: fiyat nesne
- JSON olmayan ham HTML
- Aşırı büyük mesaj (20 KB)

#	Kontrol	Sonuç
1	CSP başlığı var	GEÇTİ
2	CSP'de unsafe-inline / unsafe-eval yok	GEÇTİ
3	connect-src joker içermiyor (wss: veya * yok)	GEÇTİ
4	Trusted Types zorunlu	GEÇTİ
5	Canlı bağlantı kuruldu	GEÇTİ
6	Zararlı mesajların tamamı reddedildi (11/11)	GEÇTİ
7	Hiçbir script çalışmadı (window.__xss tanımsız)	GEÇTİ
8	alert penceresi açılmadı	GEÇTİ
9	DOM'a <img>/<script>/olay özniteliği eklenmedi	GEÇTİ
10	Prototip kirlenmedi	GEÇTİ
11	Zararlı metin ekranda görünmüyor	GEÇTİ
12	Trusted Types innerHTML yazımını engelledi	GEÇTİ
13	Satır içi script engellendi	GEÇTİ
14	İzinsiz wss adresine bağlantı CSP ile engellendi	GEÇTİ
15	Veri sızdırma isteği (fetch) engellendi	GEÇTİ
16	Yeni Trusted Types politikası oluşturulamadı	GEÇTİ
17	İkinci katmanda da script çalışmadı	GEÇTİ
18	Tarayıcı 5 CSP/Trusted Types ihlali kaydetti	GEÇTİ
19	CSP ihlal raporları sunucuya ulaştı (5 adet)	GEÇTİ
20	Kopma görünür şekilde bildirildi	GEÇTİ
21	Otomatik yeniden bağlandı	GEÇTİ
22	API kapalıyken son başarılı veriyle açıldı	GEÇTİ
23	Boş sonuç durumu gösterildi	GEÇTİ
24	360 px genişlikte yatay taşma yok	GEÇTİ



Şekil 3. Zararlı yüklerden sonra arayüz bozulmadı. Alt bilgide "Doğrulamayı geçemeyen mesaj" sayacı görünüyor.


```
{"directive": "require-trusted-types-for", "blocked":
"trusted-types-sink", "sample": "Element innerHTML|<im
g src=x onerror=\"window.__xss=2\">"}
{"directive": "require-trusted-types-for", "blocked":
"trusted-types-sink", "sample": "HTMLScriptElement tex
tContent|window.__xss=3"}
{"directive": "connect-src", "blocked": "wss://kotu-su
nucu.example.com/stream", "sample": ""}
{"directive": "connect-src", "blocked": "https://kotu-
sunucu.example.com/sizdir?d=", "sample": ""}
{"directive": "trusted-types", "blocked": "trusted-typ
es-policy", "sample": "kotu"}
```


Şekil 4. Sunucuya ulaşan CSP / Trusted Types ihlal raporları (`/csp-report` logu).

5.2 OWASP ZAP baseline: önce / sonra

Yalnızca kendi adreslerimiz tarandı (GitHub Actions, `zap.yml`). **Önce:** Aynı uygulama, edge güvenlik katmanı olmadan düz statik hosting üzerinde (`once.kripto-piyasa-panosu.pages.dev`). **Sonra-1:** Edge katmanıyla üretim. **Sonra-2:** ZAP bulgularına göre düzeltilmiş üretim.

Bulgu	Risk	Önce	Sonra-1	Sonra-2	Düzeltme	Durum
Content Security Policy (CSP) Header Not Set	Orta	**açık**	—	—	Edge'de sıkı CSP (_middleware.js)	Çözüldü
Cross-Domain Misconfiguration	Orta	**açık**	**açık**	—	Cloudflare'in varsayılan 'Access-Control-Allow-Origin: *' başlığı edge'de silindi	Çözüldü
Missing Anti-clickjacking Header	Orta	**açık**	—	—	frame-ancestors 'none' + X-Frame-Options: DENY	Çözüldü
Cross-Origin-Embedder-Policy Header Missing or Invalid	Düşük	**açık**	**açık**	—	Cross-Origin-Embedder-Policy: require-corp	Çözüldü
Cross-Origin-Opener-Policy Header Missing or Invalid	Düşük	**açık**	—	—	Cross-Origin-Opener-Policy: same-origin	Çözüldü
Permissions Policy Header Not Set	Düşük	**açık**	—	—	Kamera, mikrofon, konum, ödeme vb. kapatıldı	Çözüldü
Strict-Transport-Security Header Not Set	Düşük	**açık**	—	—	HSTS: 2 yıl, includeSubDomains, preload	Çözüldü
CSP: Notices	Düşük	—	**açık**	**açık**	Kabul edildi: report-uri bilinçli olarak korunuyor (Bölüm 8)	Kabul

Özet	Önce	Sonra-1	Sonra-2
ZAP yüksek / orta / düşük / bilgi	0 / 3 / 4 / 7	0 / 1 / 2 / 8	0 / 0 / 1 / 8
Mozilla Observatory	C (55), 10/12	A+ (145), 12/12	A+ (155), 12/12
Tarama zamanı (UTC)	Thu, 29 Oct 2026 10:06:22	Thu, 29 Oct 2026 10:06:27	Thu, 29 Oct 2026 10:25:37

"Bilgi" düzeyindeki bulgular (Base64 Disclosure, Sec-Fetch-* başlıkları, önbellek yönergeleri) sırasıyla şunlardır: Derlenmiş JS içindeki rastgele dizgeler, istemcinin göndermesi gereken başlıklar ve CDN önbellek davranışı. Güvenlik açığı değillerdir.

[Ekran görüntüsü eklenecek: observatory.png]

Şekil 5. Mozilla Observatory sonucu.

[Ekran görüntüsü eklenecek: securityheaders.png]

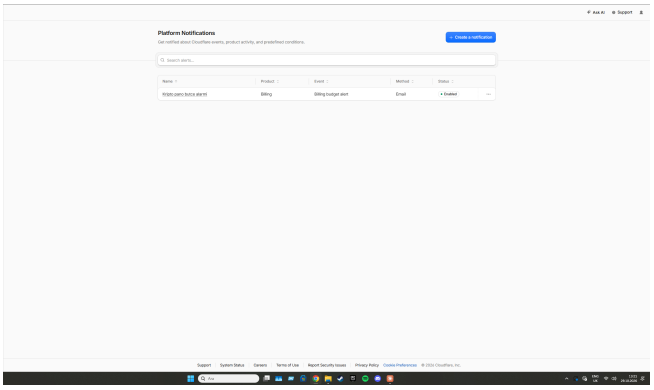
Şekil 6. securityheaders.com sonucu.

6. İzleme ve olay müdahalesi

- **Log toplama:** Erişim ve hata logları Cloudflare Pages/Workers loglarında toplanır. CSP ihlalleri `/csp-report` üzerinden yapılandırılmış JSON olarak aynı yere yazılır.
- **Alarm 1, erişilebilirlik ve güvenlik başlıkları:** `izleme.yml` saatte bir siteyi yoklar. Site 200 dönmezse, bir güvenlik başlığı kaybolursa, CSP'ye `unsafe-inline` girerse ya da security.txt kaybolursa iş başarısız olur ve GitHub e-posta ile alarm gönderir.
- **Alarm 2, kullanım:** `kullanim-bekcisi.yml` 6 saatte bir Cloudflare GraphQL Analytics'ten son 24 saatteki istek sayısını okur. 50.000'i (ücretsiz katmanın yarısı) geçerse alarm verir.
- **Alarm 3, maliyet:** Cloudflare *Billing budget alert*: 1 USD, e-posta.
- **Runbook:** `docs/runbook-anahtar-sizdi.md`. "API anahtarım sızdı" senaryosu beş adımdan oluşur: tespit (secret scanning, gitleaks, beklenmedik yayın) → iptal (≤15 dk, Cloudflare'de "Roll") → yenileme (yeni token, GitHub Secrets güncelle, yayını doğrula) → inceleme (audit log, deployment geçmişi, rollback, kök neden) → bildirim.

[Ekran görüntüsü eklenecek: izleme-alarmi.png]

Şekil 7. Saatlik izleme iş akışı (başarılı çalıştırma).



Şekil 8. Cloudflare bütçe alarmı (1 USD, e-posta, etkin).

7. Maliyet

Kalem	Ücretsiz katman	Bu projenin kullanımı (tahmin)	Maliyet
Cloudflare Pages statik istekler	Sınırsız	Ders ve demo trafiği	0 TL
Pages Functions (Workers) istekleri	100.000 / gün	Her sayfa isteği bir kez; günde birkaç yüz	0 TL
Pages derlemeleri / yüklemeleri	500 / ay	Günlük 1 + her push; ayda ~60	0 TL
GitHub Actions	Herkese açık depoda sınırsız	CI, yayın, izleme (saatlik), tarama	0 TL
Binance piyasa verisi	Anahtarsız, ücretsiz	REST 5 dk'da bir, tek WebSocket	0 TL

Cloudflare hesabında ödeme yöntemi tanımlı değildir. Ücretsiz sınırlar aşılsa bile istekler reddedilir, fatura çıkmaz. Bütçe alarmı ve kullanım bekçisi bunun üzerine ek bir uyarı katmanıdır.

8. Kalan riskler ve kabul edilenler

- **ZAP "CSP: Notices" (düşük), kabul edildi:** `report-uri` eskimiş sayılıyor. Ancak Firefox `report-to`'yu desteklemiyor, Chrome da `report-to` ile raporları yaklaşık 1 dakika biriktiriyor (testimizde ölçüldü). İhlallerin hemen ve her tarayıcıdan gelmesi için `report-uri` bilinçli olarak korunuyor.
- **Veri bütünlüğü:** Şemaya tam uyan ama yanlış bir fiyat gösterilebilir. Bu bir XSS değil, bütünlük riskidir. "Yatırım tavsiyesi değildir" notu ve kaynak bağlantısı bunu kullanıcıya bildirir.
- **Üçüncü taraf bağımlılığı:** Binance uzun süre kapalı kalırsa pano son veriyle açılır ama güncel olmaz. Bu durum ekranda açıkça yazılır.
- **Token süresi:** Token'lar 27 Ocak 2027'de dolar. Site çalışmaya devam eder ama yayın durur. Hatırlatma kuruldu, runbook adımları geçerli.
- **Scorecard'ın kapanamayan maddeleri:** *Code-Review* (tek geliştirici; PR'lar başkasınca onaylanmıyor), *Maintained* (depo 90 günden yeni), *Fuzzing* ve *CII-Best-Practices* (ders projesi kapsamı dışında).
- **Önizleme dalı:** ZAP "önce" taraması için güvenlik katmanı olmayan bir önizleme yayını (`once`. alt alan adı) açıldı. Aynı uygulama olduğu için ek bir veri açığı yok. Demodan sonra Cloudflare'den silinecek.

Kanıt dosyaları: `test/evidence/` (doğrulama testi), `docs/kanit/zap-1`, `docs/kanit/zap-2` (ZAP HTML/JSON + Observatory), `docs/kanit/ekran/` (ekran görüntüleri). Yapay zekâ beyanı README'dedir.